

AUDSPECT

Breach & Attack Simulation Platform

Adversary Simulation Assessment Report

APT36 Kill Chain (Three-Tier)

RISK: CRITICAL

Prepared for	DESKTOP-5TVEBSI
Endpoint	Windows/amd64 (10.0.19045)
Environment	Production
Assessment date	10 June 2026, 11:29 UTC
Report generated	10 June 2026, 11:30 UTC
Run reference	18b7b4cd

1. Executive Summary

This report presents the results of an automated breach & attack simulation executed against DESKTOP-5TVEBSI (Windows/amd64 (10.0.19045)) on 10 June 2026. The assessment ran 15 MITRE ATT&CK-aligned techniques to measure how effectively the endpoint's security controls prevent real adversary behaviour.

Of the techniques executed, 7 were prevented or blocked by a security control and 8 executed successfully without being stopped. This yields a prevention effectiveness of 47% and an overall risk classification of Critical (risk score 90/100). Consecutive failures across adjacent kill-chain phases amplified exposure by 1.8×, indicating an attacker could chain multiple steps with limited resistance.

7 critical or high-severity technique(s) were not prevented and require prioritised remediation (see Key Findings). Testing exercised 57% of the ATT&CK enterprise kill chain; broadening scenario coverage in future runs will increase assurance. Prioritised recommendations are provided in section 7.

Overall posture: Critical (risk score 90 / 100, Baseline)

15 techniques · 7 prevented · 8 succeeded · 0 errored · 0 skipped · 7 critical/high finding(s)

2. Assessment Scorecard



3. Methodology & Scope

Framework	MITRE ATT&CK (Enterprise)
Engines	Custom checks
Target endpoint	DESKTOP-5TVEBSI — Windows/amd64 (10.0.19045)
Environment	Production
Techniques executed	15
Tactics exercised	6 of 14 ATT&CK tactics
Window	10 Jun 2026 11:29 UTC

Each technique is scored as PASS when a security control prevented or blocked it, FAIL when it executed without being stopped, ERROR when the test itself could not execute correctly (malformed content, timeout, missing prerequisite, scheduler contention), or SKIPPED when it was not run. Only PASS and FAIL count toward the score: a FAIL is a finding — the simulated adversary behaviour succeeded against this endpoint — while ERROR and SKIPPED are excluded because they reflect a test-execution problem, not the endpoint's defences.

4. ATT&CK Tactic Breakdown

Initial Access		66%	2 pass · 1 fail
Execution		0%	0 pass · 2 fail

Persistence — Confidential		36 K50%ain (Th1 pass)1 fail
Defense Evasion		0%0 pass · 2 fail
Credential Access		100%2 pass · 0 fail
Collection		100%1 pass · 0 fail

5. Key Findings

CRITICAL

F-01 T1566.001 — Office VBA Macro Execution Policy

Initial Access

What happened	No Office macro restriction policy found — VBA payloads may execute on document open.
Remediation	Block macros from internet via GPO: User Config . Administrative Templates . Microsoft Office . Security Settings . VBA Macro Notification Settings = 4.

CRITICAL

F-02 T1566.001 — ASR Rule — Block Office Child Process Spawning

Prevention Posture

What happened	ASR rule D4F940AB not configured — Office can spawn cmd.exe/powershell.exe (APT36 initial access vector open).
Remediation	Enable ASR rule D4F940AB-401B-4EFC-AADC-AD5F3C50688A via GPO (Block Office apps from creating child processes).

HIGH

F-03 T1559.001 — ASR Rule — Block Win32 API Calls from Office Macros

Prevention Posture

What happened	ASR rule 3B576869 not configured — Office macros can invoke Win32 APIs and COM objects (APT36 GetObject/CreateObject vector open).
Remediation	Enable ASR rule 3B576869-A4EC-4529-8536-B80A7769E899 via GPO (Block Win32 API calls from Office macros).

CRITICAL

F-04 T1218.005 — mshta.exe Execution Control

Execution

What happened	mshta.exe not explicitly blocked — APT36 HTA dropper execution via spear-phish attachment is possible.
Remediation	Block mshta.exe via AppLocker Publisher rule or WDAC deny policy. Enable ASR rule: Block Office child processes.

HIGH

F-05 T1059.005 — WScript/CScript Execution Control

Execution

What happened	WScript/CScript not restricted — VBScript payloads from APT36 documents can execute freely.
Remediation	Disable VBScript in Internet Zone (Zone 3, setting 1400=3). Block wscript.exe/cscript.exe via AppLocker.

HIGH

F-06 T1059.001 — PowerShell Script Block Logging

Defense Evasion

What happened	Script Block Logging not configured — PowerShell attack activity not logged to Event ID 4104.
Remediation	Enable via GPO: Computer Config . PS . Script Block Logging . Enabled.

HIGH

F-07 T1053.005 — Scheduled Tasks Running from User-Writable Paths

Persistence

What happened	1 scheduled task(s) run from Temp/AppData — APT36 persistence pattern detected, manual review required.
Remediation	Audit schtasks for Temp/AppData actions. Block execution from user-writable paths via AppLocker/WDAC.

6. Detailed Technique Results

FAIL

T1566.001 — Office VBA Macro Execution Policy

Initial Access · Critical

Details	No Office macro restriction policy found — VBA payloads may execute on document open.
Threat impact	APT36 delivers CrimsonRAT/ObliqueRAT via weaponised Office documents — VBA macro execution is the initial foothold.

PASS

T1566.001 — Office Protected View (Internet-Sourced Files)

Initial Access · High

Details	DisableInternetFilesInPV absent — Protected View for internet files is ON (default).
Threat impact	Disabled Protected View lets phishing attachments execute macros on open without user interaction.
Remediation	Verify Protected View is on: Office Trust Center . Protected View . enable all three checkboxes.

PASS

T1566.001 — Mark of the Web (MOTW) Enforcement

Initial Access · High

Details	Attachment manager scans downloads with antivirus (ScanWithAntiVirus=3) — MOTW processing active.
Threat impact	APT36 packs HTA droppers inside ZIP/ISO to bypass MOTW and execute without Protected View.
Remediation	Apply KB5016616+ (Win11 22H2) so MOTW propagates to archive contents. Use Defender ASR rule for Office child processes.

FAIL

T1566.001 — ASR Rule — Block Office Child Process Spawning

Prevention Posture · Critical

Details	ASR rule D4F940AB not configured — Office can spawn cmd.exe/powershell.exe (APT36 initial access vector open).
Threat impact	APT36 weaponised documents spawn cmd.exe/powershell.exe as Office child processes to execute CrimsonRAT. This ASR rule directly blocks that chain.
Remediation	Enable ASR rule D4F940AB-401B-4EFC-AADC-AD5F3C50688A via GPO (Block Office apps from creating child processes).

FAIL

T1559.001 — ASR Rule — Block Win32 API Calls from Office Macros

Prevention Posture · High

Details	ASR rule 3B576869 not configured — Office macros can invoke Win32 APIs and COM objects (APT36 GetObject/CreateObject vector open).
Threat impact	APT36 uses Office COM automation (GetObject/CreateObject) to execute payloads without spawning a visible child process, evading process-chain detections.
Remediation	Enable ASR rule 3B576869-A4EC-4529-8536-B80A7769E899 via GPO (Block Win32 API calls from Office macros).

FAIL

T1218.005 — mshta.exe Execution Control

Execution · Critical

Details	mshta.exe not explicitly blocked — APT36 HTA dropper execution via spear-phish attachment is possible.
Threat impact	APT36 uses mshta.exe to execute HTA payloads — a signed Windows binary that bypasses most script restrictions.
Remediation	Block mshta.exe via AppLocker Publisher rule or WDAC deny policy. Enable ASR rule: Block Office child processes.

FAIL

T1059.005 — WScript/CScript Execution Control

Execution · High

Details	WScript/CScript not restricted — VBScript payloads from APT36 documents can execute freely.
Threat impact	APT36 uses VBScript via wscript.exe for second-stage payload execution after the HTA dropper.
Remediation	Disable VBScript in Internet Zone (Zone 3, setting 1400=3). Block wscript.exe/cscript.exe via AppLocker.

PASS

T1562.001 — AMSI Enforcement (Anti-Malware Scan Interface)

Detection Posture · High

Details	AMSI enabled with 1 registered provider(s) — PowerShell, VBScript, and Office macro content scanned at runtime.
Threat impact	APT36 PowerShell stagers and CrimsonRAT loaders use AMSI bypass techniques to evade real-time script scanning before initial execution.
Remediation	Ensure AmsiEnable.0 in HKCU\SOFTWARE\Microsoft\Windows Script\Settings. Deploy EDR with AMSI provider integration.

FAIL

T1059.001 — PowerShell Script Block Logging

Defense Evasion · High

Details	Script Block Logging not configured — PowerShell attack activity not logged to Event ID 4104.
Threat impact	Without Script Block Logging, malicious PowerShell is executed and exfiltrated unlogged.

FAIL	T1562.001 — Sysmon Endpoint Monitoring Defense Evasion · Medium
Details	Sysmon not installed — limited endpoint visibility for threat hunting.
Threat impact	Without Sysmon, process injection, network connections, and file drops are not logged.
Remediation	Deploy Sysmon with SwiftOnSecurity or Olaf config on all endpoints.
PASS	T1056.001 — Keylogger Indicator Detection Collection · High
Details	No processes with obvious keyboard-hook module names found in running process list.
Threat impact	UPI fraud malware deploys keyloggers to capture banking passwords, transaction PINs, and UPI authentication credentials.
Remediation	Deploy EDR with SetWindowsHookEx detection. Enable Credential Guard to protect credentials in memory.
FAIL	T1053.005 — Scheduled Tasks Running from User-Writable Paths Persistence · High
Details	1 scheduled task(s) run from Temp/AppData — APT36 persistence pattern detected, manual review required.
Threat impact	APT36 creates scheduled tasks pointing to %TEMP%/APPDATA% to persist CrimsonRAT across reboots.
Remediation	Audit schtasks for Temp/AppData actions. Block execution from user-writable paths via AppLocker/WDAC.
PASS	T1547.001 — Run Registry Key Inspection Persistence · High
Details	HKLM Run key: 4 entry/entries found — review any unknown entries.
Threat impact	Attackers add entries to Run keys to persist malware across reboots.
Remediation	Audit HKLM\...\CurrentVersion\Run entries. Use Autoruns (Sysinternals) regularly.
PASS	T1555.003 — Browser Saved Credential Store Exposure Credential Access · Critical
Details	No browser credential databases found, or password manager disabled by policy.
Threat impact	APT36 steals banking portal credentials from Chrome/Edge Login Data — a SQLite database readable without elevation.
Remediation	Disable browser password managers via enterprise policy. Use a PAM vault for banking system credentials.
PASS	T1552.002 — AutoLogon Credentials in Registry Credential Access · Critical
Details	AutoLogon disabled — no plaintext credentials stored in registry.
Threat impact	AutoLogon stores credentials in plaintext in the registry, readable by any local process.
Remediation	Disable AutoLogon: clear HKLM\...\Winlogon\AutoAdminLogon and DefaultPassword.

7. Prioritised Recommendations

- Overall prevention score is critically low. Prioritise endpoint hardening and EDR deployment across all assets.
- Kill-chain amplifier is 1.8× — an attacker can traverse multiple consecutive kill-chain phases unimpeded. Implement network segmentation and lateral movement controls.

8. Appendix — Metric Definitions

PASS	A security control prevented or blocked the simulated technique. More passes is better.
FAIL	The technique executed successfully without being stopped — a finding requiring attention.
ERROR	The test could not execute correctly (malformed content, timeout, missing prerequisite, scheduler contention). A BAS execution problem, not a security outcome — excluded from scoring.
SKIPPED	The technique was deliberately not run (e.g. external payload not shipped) and was excluded

	from scoring.
Prevention	Severity-weighted percentage of techniques that were prevented. Higher is better.
Exposure	Tactic-weighted failure rate, amplified by consecutive kill-chain failures. Lower is better.
Tactic Coverage	Breadth of testing: how many of the 14 MITRE ATT&CK Enterprise tactics this run exercised.
Defense Rate	Share of tested tactics in which every technique was blocked (zero failures).
Kill-chain amplifier	Multiplier (1.0–2.5×) reflecting consecutive unprevented kill-chain phases.
Risk classification	Overall posture band derived from the amplified exposure score.